

---

# The Next Generation

---

MIHIR BELLARE

University of California San Diego

# Topics

1. Next generation authenticated encryption.
2. Next generation research and researchers.

## Definitional evolution of nonce-based AE

AE1 = AEAD [RBBK01,Ro02]

Flaws and issues [BNT16]

AE2 [BNT16]

Very good security

But can incur unnecessary cost

AE5 [NRS13]

AE3 [BS23]

General, AE1 and AE2 special cases, unnecessary costs removed

But inherit the AE1 flaws

?

Finding a really satisfactory definition for AE is open.

## Scope and focus

AE asks for **authenticity** and **privacy**

In fact, our concern will be just **privacy**.

There are many other properties one may want from a symmetric encryption scheme:

- **Committing** (CMT) security [...,BH22,CR22]
- **Misuse resistance** (MRAE) [RS07]
- **Release of unverified plaintext** (RUP) [ABLMMY14]
- ...

These are orthogonal to today's discussion.  
Meaning, they can be added, or not, as desired.



Today's talk is

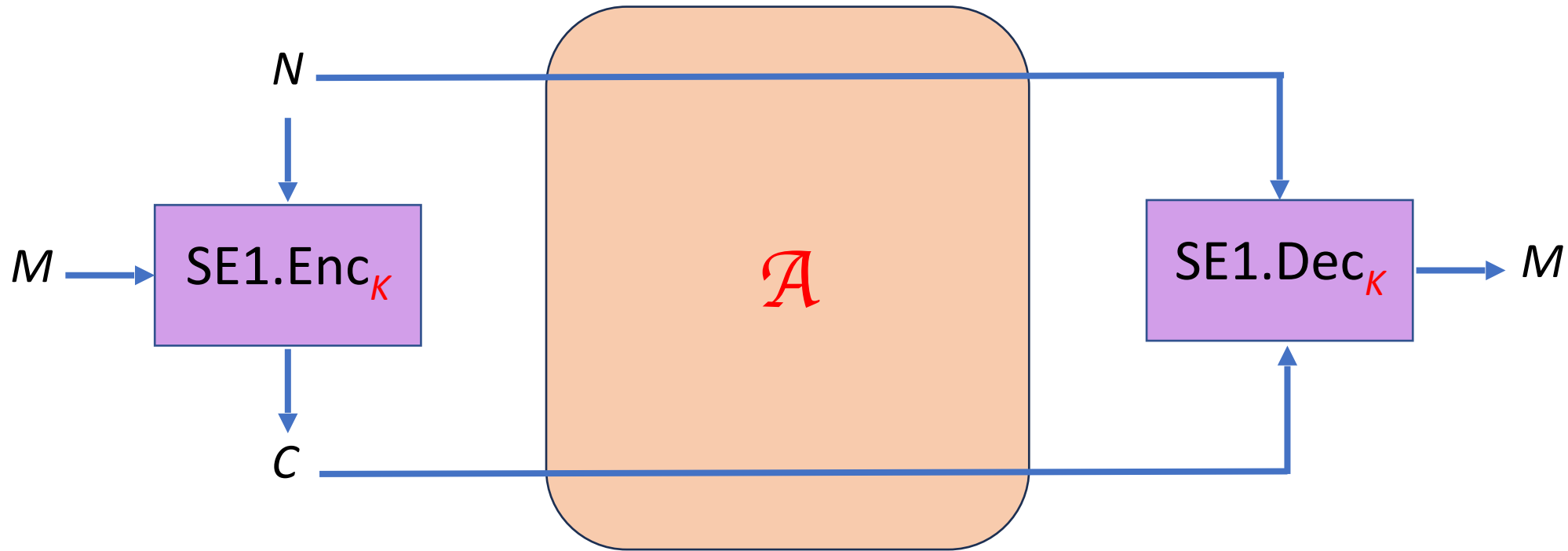


**back to basics**: just plain basic  
**privacy**.

**back in time**: question and critique some  
OLD, standard definitions.



## AE1 / AEAD : Authenticated Encryption Today



$M$  : Message

$N$  : Nonce

$C$  : Ciphertext

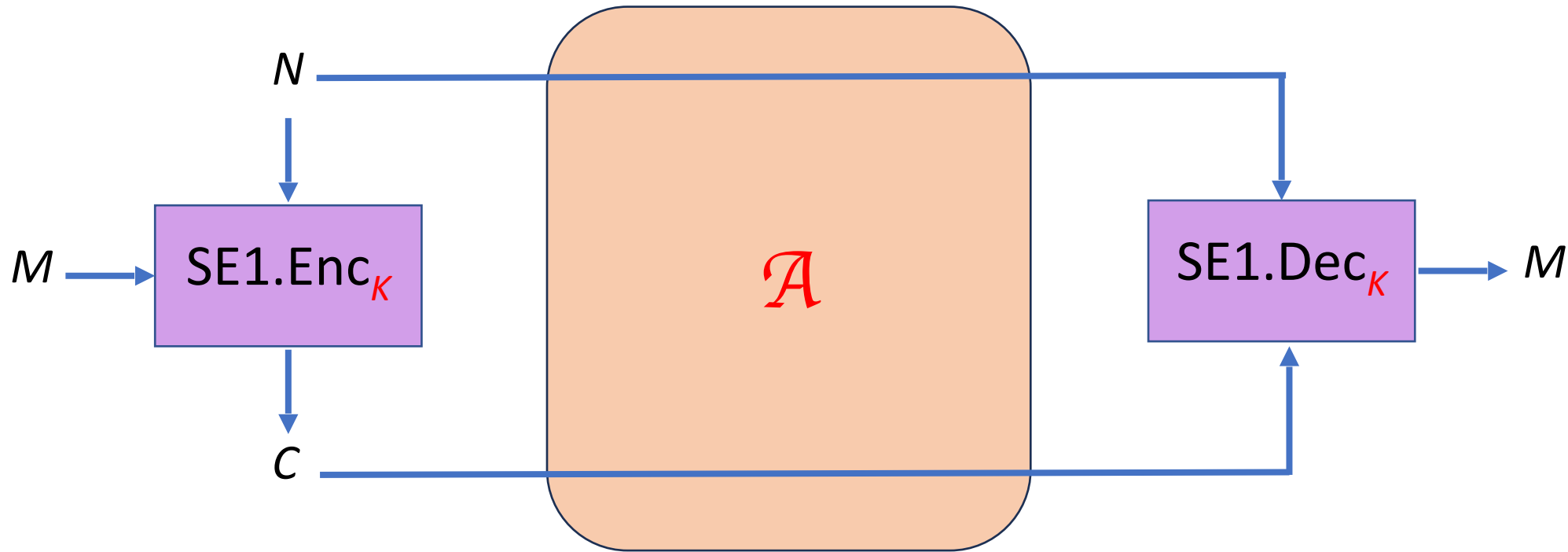
$K$  : Key

Scheme SE1 specifies encryption algorithm  $\text{SE1.Enc}$  and decryption algorithm  $\text{SE1.Dec}$ .  
Note that the decryption algorithm needs and gets the nonce  $N$  as input as per the AE1 syntax.

**Example Schemes:** GCM, OCB, ...

**Security goal:** Privacy of message  $M$  and authenticity of  $C$

## AE1 / AEAD : Authenticated Encryption Today



$M$  : Message  
 $N$  : Nonce  
 $C$  : Ciphertext  
 $K$  : Key

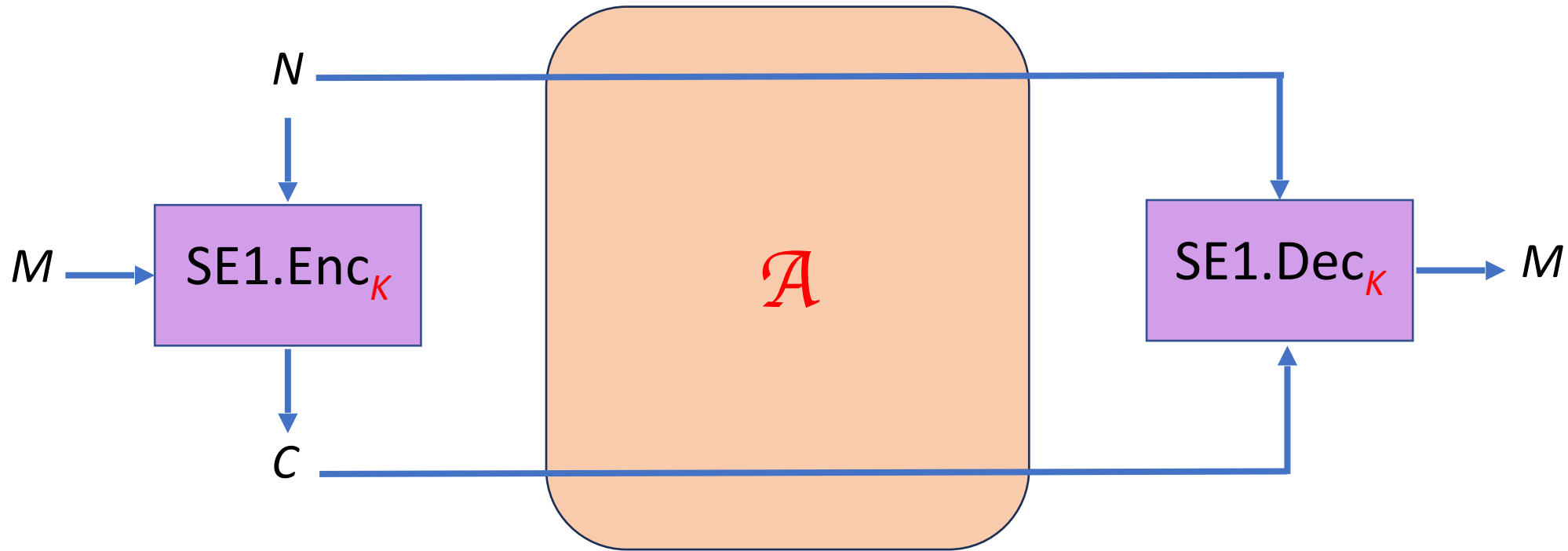
Scheme SE1 specifies encryption algorithm  $\text{SE1.Enc}$  and decryption algorithm  $\text{SE1.Dec}$ .  
Note that the decryption algorithm needs and gets the nonce  $N$  as input as per the AE1 syntax.

**Example Schemes:** GCM, OCB, ...

**Security goal:** Privacy of message  $M$

Our concern is privacy so we drop the associated data

## AE1 / AEAD : Authenticated Encryption Today



$M$  : Message

$N$  : Nonce

$C$  : Ciphertext

$K$  : Key

AE1 allows **ANY** choice of nonce.

The only restriction is that a nonce should not be reused across different encryptions.

## An Interface and Algorithms for Authenticated Encryption

### [3.1.](#) Requirements on Nonce Generation

It is essential for security that the nonces be constructed in a manner that respects the requirement that each nonce value be distinct for each invocation of the authenticated encryption operation, for any fixed value of the key. In this section, we call

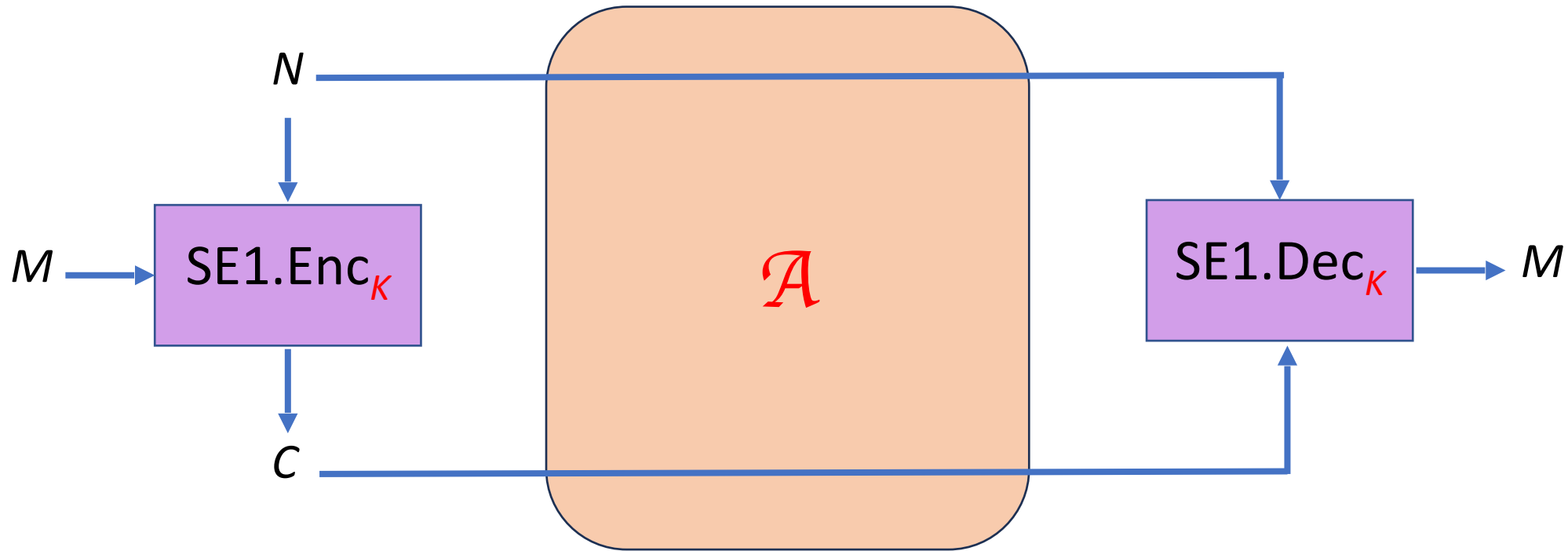
### [3.2.](#) Recommended Nonce Formation

The following method to construct nonces is RECOMMENDED. The nonce is formatted as illustrated in Figure 1, with the initial octets consisting of a Fixed field, and the final octets consisting of a Counter field. For each fixed key, the length of each of these fields, and thus the length of the nonce, is fixed. Implementations SHOULD support 12-octet nonces in which the Counter field is four octets long.

```

<----- variable -----> <----- variable ----->
+-----+-----+-----+-----+
|           Fixed           |           Counter           |
+-----+-----+-----+-----+
```

## AE1 / AEAD : Authenticated Encryption Today



$M$  : Message

$N$  : Nonce

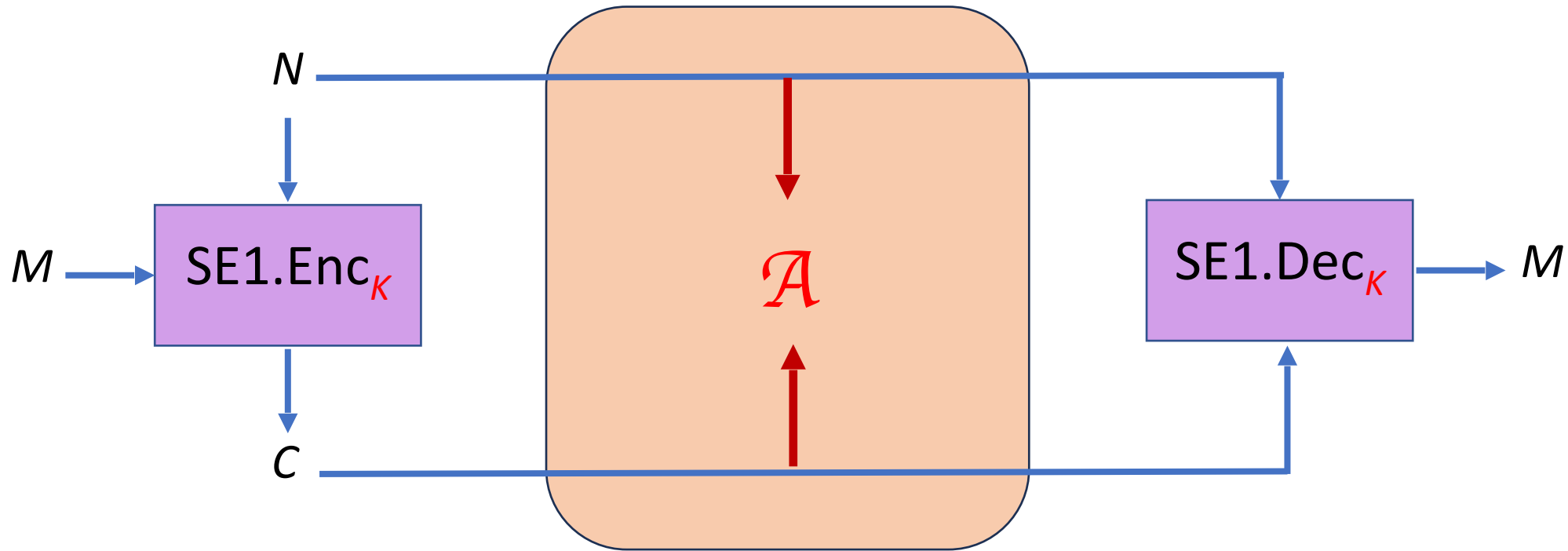
$C$  : Ciphertext

$K$  : Key

**The AE1 claim:** Privacy of message  $M$  is provided REGARDLESS of the choice of the nonce.

Yet it should be obvious from the above picture that **this claim is not true**.

## AE1 / AEAD : Authenticated Encryption Today



$M$  : Message  
 $N$  : Nonce  
 $C$  : Ciphertext  
 $K$  : Key

**The AE1 claim:** Privacy of message  $M$  is provided REGARDLESS of the choice of the nonce.

Yet it should be obvious from the above picture that **this claim is not true**.

Why? Because there exist ``**UNSAFE**'' choices of nonces.

Namely, nonces that carry information about  $M$ . For example:

- $N = \text{SHA256}(M)$ , or even
- $N = M$

Suppose we want to encrypt distinct messages  $M_1, M_2, \dots$  with an AE1 scheme SE1.

The messages are from some known, relatively small “dictionary”  $D$ .

Nothing wrong with that; adversary should not learn which message from  $D$  was encrypted.

But SE1 needs a nonce per message. What should we use?

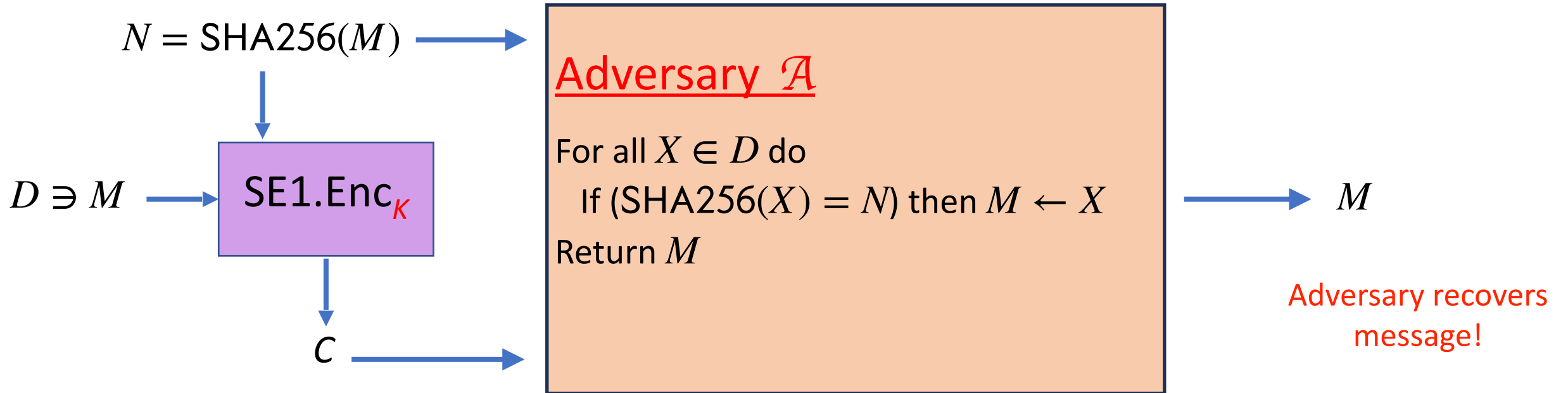
**Suggestion:** Let's use  $N_i = \text{SHA256}(M_i)$  as the nonce when encrypting message  $M_i$ .

The nonces  $N_1, N_2, \dots$  will be **distinct**, so AE1 should provide message privacy.

This choice of nonces is STANDARDS COMPLIANT.

**Problem:** Privacy fails. **Adversary can easily recover the messages.**

## An attack on AE1



This attack works for ANY AE1 scheme, for example GCM, OCB, ...

Nonces need protection too.

Because,

If we don't hide the nonce,

Then we may not succeed in our main goal  
of hiding the message.

But once we think about hiding nonces, we see that there are other  
reasons to do it too ...

## More unsafe nonces?

Nonces are **meta-data**. Recommended and used choices such as **counters**, **device identities**, **disk-sector numbers**, **packet headers**, ... can reveal information about the system and identity of the sender.

### RFC 5116

When there are multiple devices performing encryption ... use a nonce format that contains a field that is distinct for each one of the devices.

But this nonce will reveal the device identity

### [Ro13, Real World Crypto]

AE1-secure schemes provide anonymity because the ciphertext is indistinguishable from random.

But the nonce can violate anonymity

**Choice 1:** Standards should mandate SAFE nonce choices.

- Applications and implementations burdened by having to ensure their choices are safe
- No clear definition of, or agreement about, what is ``SAFE''
- Error-prone

**Choice 2:** Standardize and use AE2.

- AE2 hides the nonce, so now **ALL** nonce choices are SAFE!
- Applications and implementors can TRULY use ANY (non-repeating) choices.
- AE2 schemes are cheap

## FMO : Frequently Made Objections

This is SILLY. There really isn't a problem.

## Some answers

## FMO : Frequently Made Objections

This is SILLY. There really isn't a problem.

AE1 schemes have PROOFS showing they meet formal DEFINITIONS of privacy. So how can they not provide privacy?

## Some answers

The problem is the DEFINITION.

## FMO : Frequently Made Objections

This is SILLY. There really isn't a problem.

AE1 schemes have PROOFS showing they meet formal DEFINITIONS of privacy. So how can they not provide privacy?

## Some answers

The problem is the DEFINITION.

The problem is difficult to see with IND\$

So let us consider classical IND

Adversary provides  $N, M_0, M_1$ .

It gets back  $C \leftarrow \text{SE1.Enc}(K, N, M_b)$  where  $b$  is the hidden challenge bit that it has to guess.

But here the SAME nonce  $N$  is used regardless of  $b$ .

In our attack,  $N = \text{SHA256}(M_b)$  is a function of the message and hence of  $b$ .

And the adversary gets back this  $N$  together with  $C$ .

# FMO : Frequently Made Objections

This is SILLY. There really isn't a problem.

AE1 schemes have PROOFS showing they meet formal DEFINITIONS of privacy. So how can they not provide privacy?

I do not use unsafe nonces.

## Some answers

The problem is the DEFINITION.

Great!

But they are ALLOWED.

By research papers and standards.

# FMO : Frequently Made Objections

This is SILLY. There really isn't a problem.

AE1 schemes have PROOFS showing they meet formal DEFINITIONS of privacy. So how can they not provide privacy?

I do not use unsafe nonces.

The desideratum (and point) of a standard is that, if your implementation conforms to the standard, it is secure. This is NOT the case with standardized AE1. There are nonce choices allowed by the standard that result in message exposure.

$N = \text{SHA256}(M)$  is a natural and desirable choice that actually can occur in practice.

## Some answers

The problem is the DEFINITION.

Great!

But they are ALLOWED.

By research papers and standards.

**NIST, at their 2023 workshop**

# FMO : Frequently Made Objections

This is SILLY. There really isn't a problem.

AE1 schemes have PROOFS showing they meet formal DEFINITIONS of privacy. So how can they not provide privacy?

I do not use unsafe nonces.

Have you found any attack in the wild?  
No reason to worry until then.

## Some answers

The problem is the DEFINITION.

Great!

But they are ALLOWED.

By research papers and standards.

Be proactive, not reactive.

Prevention is better than cure.

# FMO : Frequently Made Objections

This is SILLY. There really isn't a problem.

AE1 schemes have PROOFS showing they meet formal DEFINITIONS of privacy. So how can they not provide privacy?

I do not use unsafe nonces.

Have you found any attack in the wild?  
No reason to worry until then.

We can trust applications, libraries and implementors to  
make safe nonce choices.

## Some answers

The problem is the DEFINITION.

Great!

But they are ALLOWED.

By research papers and standards.

Be proactive, not reactive.

Prevention is better than cure.

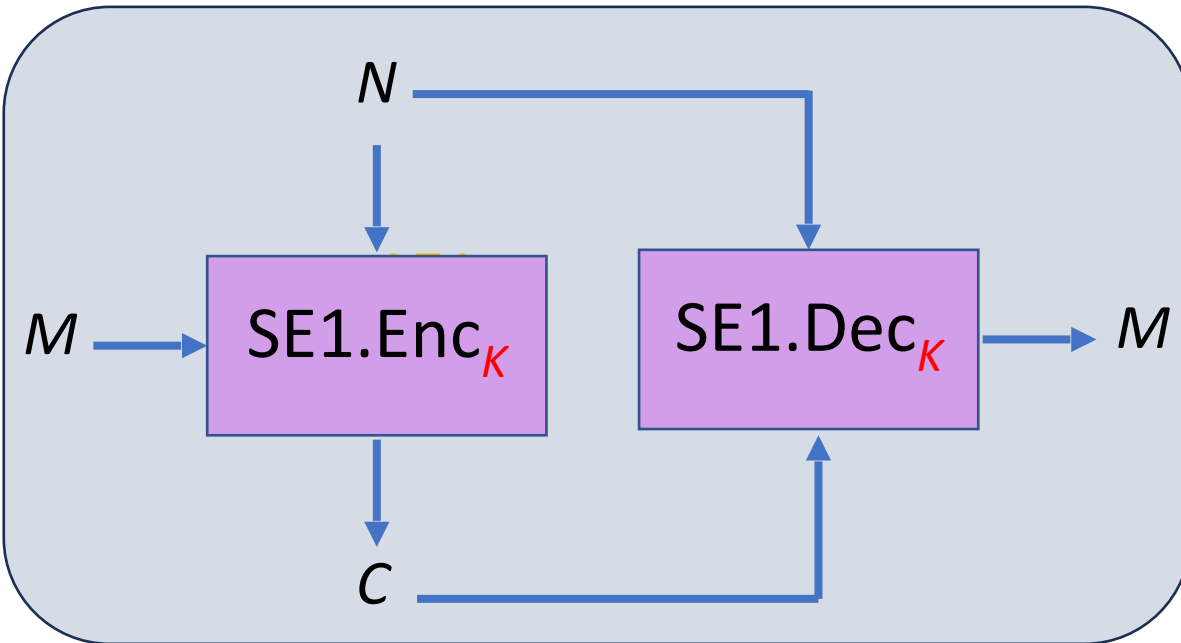
We should reduce the chance of error

We should make implementors' lives easier.

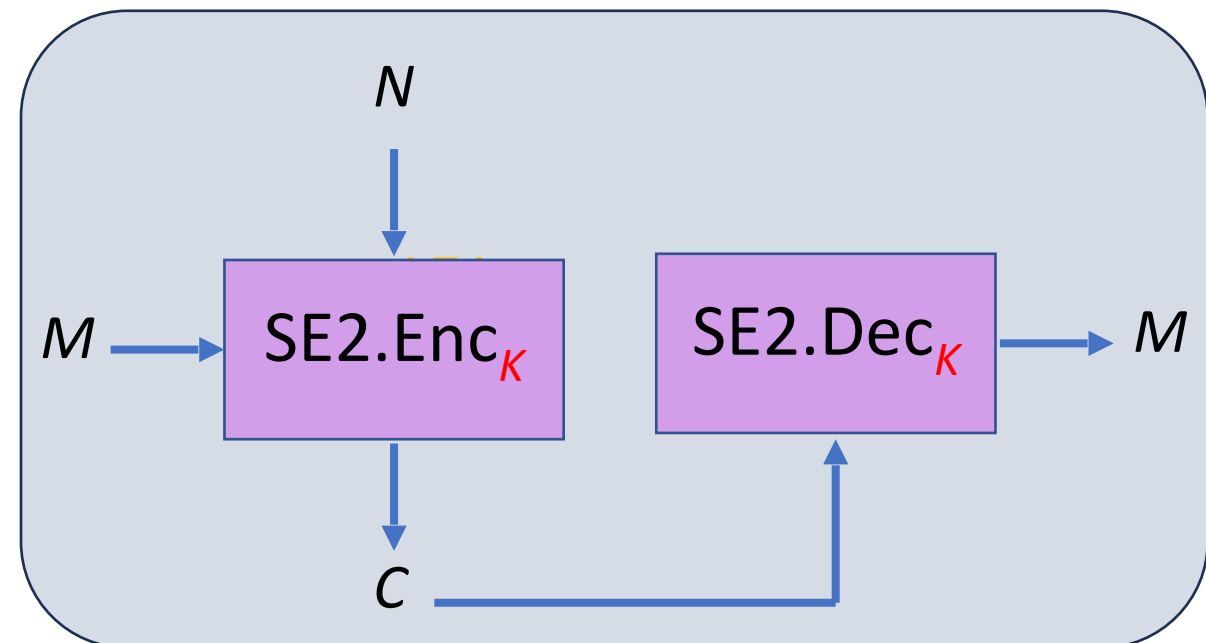
# SYNTAX of an authenticated encryption scheme

**AE1** [RBBK01,Ro02]

**AE2** [BNT16]



Nonce  $N$  is **INPUT** to **BOTH**  
SE1.Enc and SE1.Dec



Nonce  $N$  is **INPUT** to SE2.Enc  
but **NOT** to SE2.Dec

## Recall AE1 security [RBBK01,Ro02]



Adversary has black-box access to Enc and Dec oracles. But it **cannot repeat a nonce to Enc**

Note that the Dec oracle gets a nonce as explicit input from the adversary

AE1 definitions assume the nonce is sent securely and out-of-band to the receiver

But in practice, it is sent in the clear along with the ciphertext, unless the receiver already has it.

This is the notion of security that GCM, OCB and some CAESAR candidates have been proven secure under.

## AE2 security [BNT19]



Adversary has black-box access to Enc and Dec oracles. But it **cannot repeat a nonce to Enc**

Note that the Dec oracle **DOES NOT GET** a nonce input from the adversary

AE2 does not assume nonces are sent out of band. Decryption must be possible given **ONLY** the ciphertext  $C$ .

## The AE1 attack fails for AE2

Suppose we want to encrypt distinct messages  $M_1, M_2, \dots$  with an AE2 scheme SE2.

The messages are from some known, relatively small “dictionary”  $D$ .

Nothing wrong with that; adversary should not learn which message from  $D$  was encrypted.

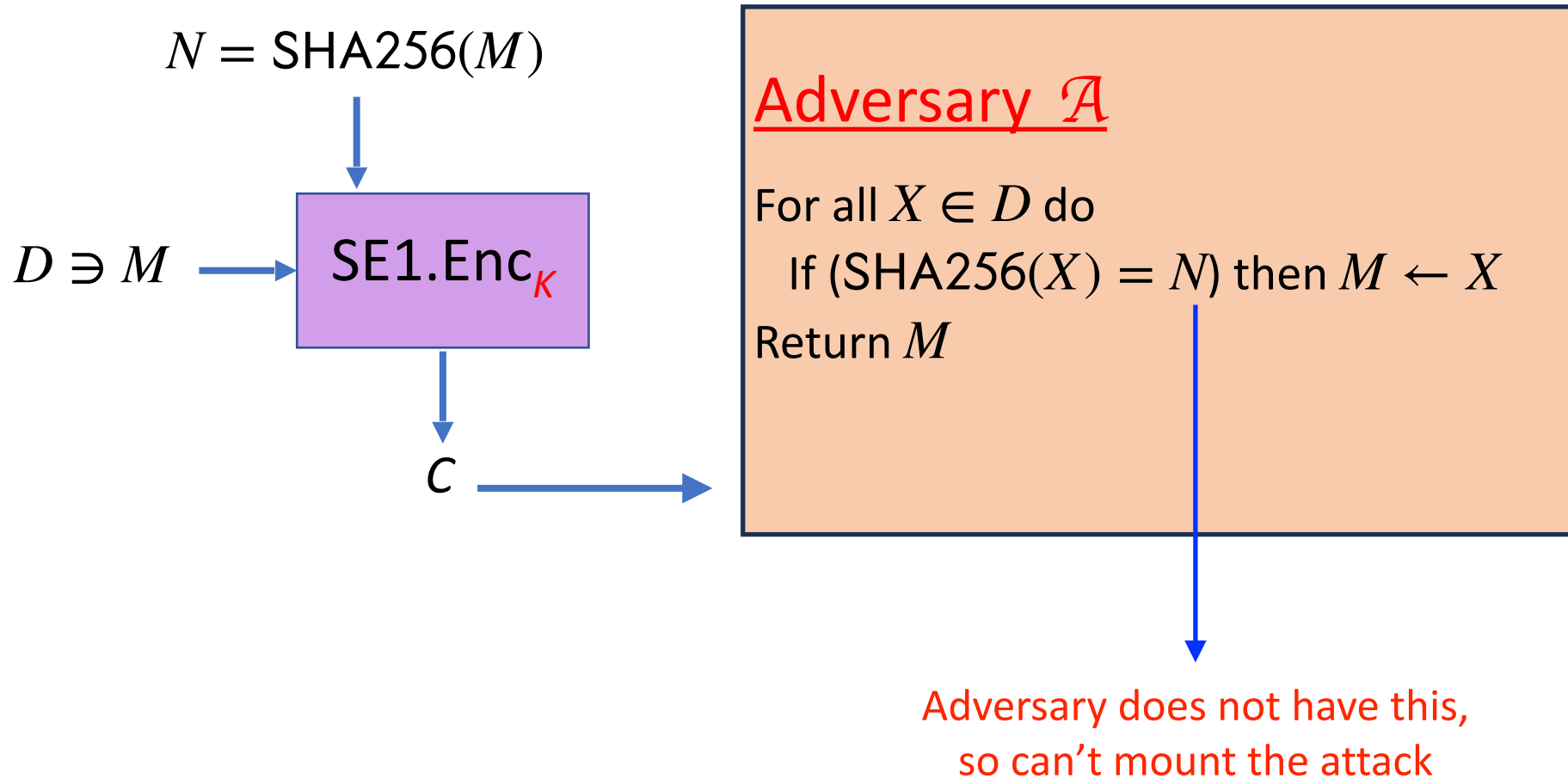
But SE2 needs a nonce per message. What should we use?

**Suggestion:** Let’s use  $N_i = \text{SHA256}(M_i)$  as the nonce when encrypting message  $M_i$ .

The nonces  $N_1, N_2, \dots$  will be **distinct**, so AE2 should provide message privacy.

**Good news:** It DOES provide privacy. **Adversary cannot recover the messages as before because it does not have the nonce.**

## The AE1 attack fails for AE2

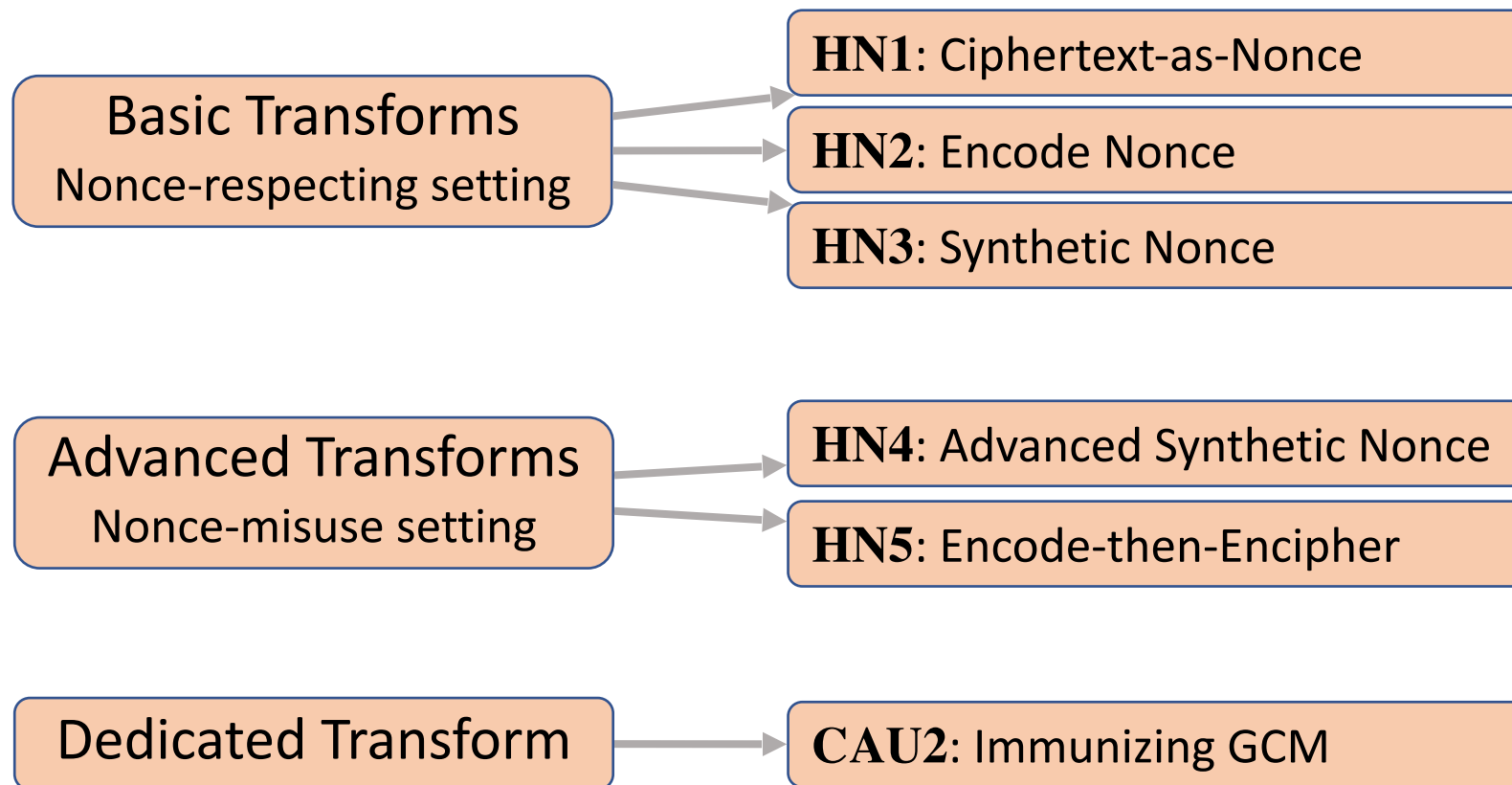


[BNT19] construct AE2 schemes from AE1 schemes, rather than from scratch, because

- There are many efficient, optimized, standardized, deployed AE1 schemes
- Application designers can now easily add nonce-hiding to them



The [BNT19] constructions have minimal (optimal) bandwidth overhead and low (like, one block-cipher call) computational overhead.



Extends AE2-security to the nonce-misuse setting, as [RS06] extended AE1-security.

CAU2 immunizes GCM with lower overhead than generic transforms.

**Good**



## **Assessing AE2**

Very good privacy

Good

## Assessing AE2

Not so good



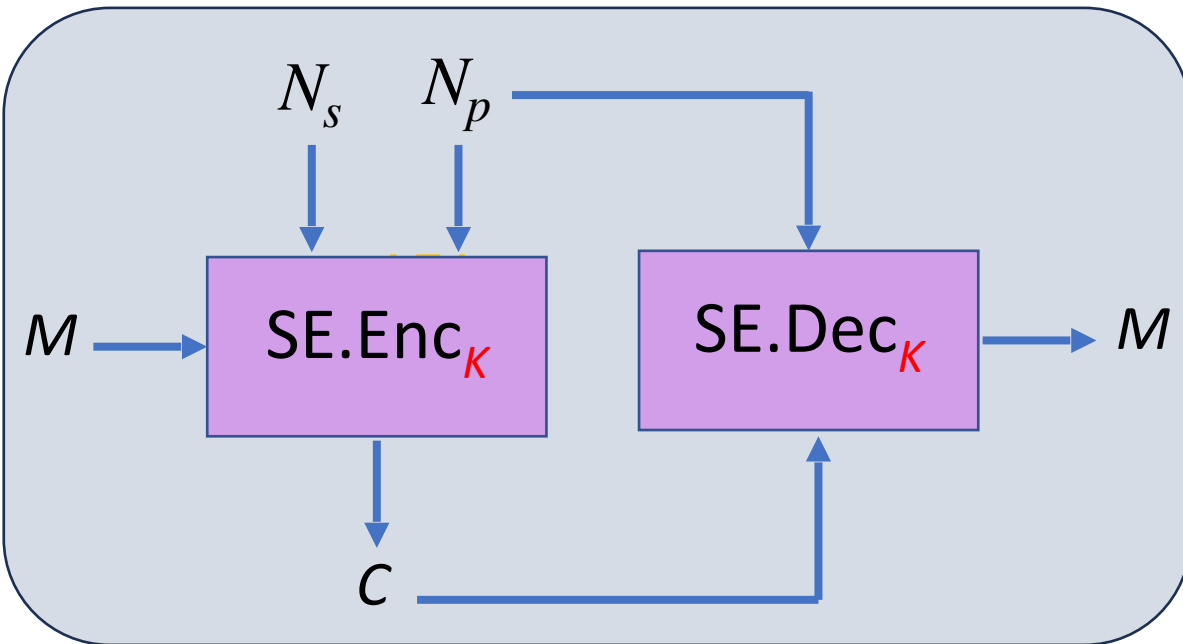
Very good privacy

Schemes encrypt nonce by default.  
But when the nonce is random, or a TLS counter, this is not  
necessary. For security, no harm.  
But it leads to unnecessary computational overhead.



**AE5** [NRS13]

**AE3** [BeSh23]



Nonce  $N = N_s || N_p$

$N_p$  : Public component of nonce

$N_s$  : Secret component of nonce

Public nonce  $N_p$  is **INPUT** to **BOTH** SE1.Enc and SE1.Dec

Secret nonce  $N_s$  is **INPUT** to SE1.Enc but **NOT** SE1.Dec

Good



## Assessing AE5

AE1 is a special case

$$N = N_p \text{ and } N_s = \varepsilon$$

AE2 is a special case

$$N_p = \varepsilon \text{ and } N = N_s$$

Avoids AE2 overhead:

Random or TLS counter nonces can go in  $N_p$

Sensitive nonces can go in  $N_s$

Good



## Assessing AE5

AE1 is a special case  
 $N = N_p$  and  $N_s = \varepsilon$

Not so good



Good



## Assessing AE5

AE1 is a special case  
 $N = N_p$  and  $N_s = \varepsilon$

Not so good



If a special case of something is insecure, so is the something itself.  
Since AE1 is a special case of AE5, all its weaknesses are too, meaning are inherited BY AE5.

Danger of choice

Who decides what nonces (or nonce components) are sensitive?

How does one decide? Not easy.

Implementors may just default to AE1: Put the entire nonce in  $N_p$

# Open Question: Can one give a better definition of AE?

Does not have the privacy weaknesses of AE1

Has an AE2 level of privacy without the AE2 computational and bandwidth overhead.

Unlike AE5, is not easily misused

Choice is **REDUCED** to avoid the danger of choice.



# The AE zoo

|     |                                                                                                                       |                                                                    |
|-----|-----------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------|
| AE1 | Insecure. Can fail to provide even basic MESSAGE privacy.<br>Additionally (and related), no option for nonce privacy. | Use, at best, if nonces are random?                                |
| AE2 | Very good privacy, for both messages and nonces.<br>But unnecessary cost in some important use cases.                 | Use if security is the primary concern.                            |
| AE5 | Flexible, can provide good privacy.<br>But can be misused.                                                            | Use if cost is also important and you can make good nonce choices. |
| AE3 | The most general, AE5 a special case.<br>But increased generality may not be worth the increased complexity.          |                                                                    |

## Next generation AE

It is time to drop AE1 / AEAD.  
New schemes and standards should target AE5.

# Next generation AE

It is time to drop AE1 / AEAD.  
New schemes and standards should target AE5.

NIST will soon standardize a block cipher with 256 bit keys and blocks  
(Rijndael-256)



Alongside they want to standardize an associated AE scheme



The current proposal **wGCM** is a direct adaptation of GCM:  
192-bit nonces, BUT

- Still AE1
- And inherits other GCM flaws: catastrophic failure under nonce reuse, no committing security, ...

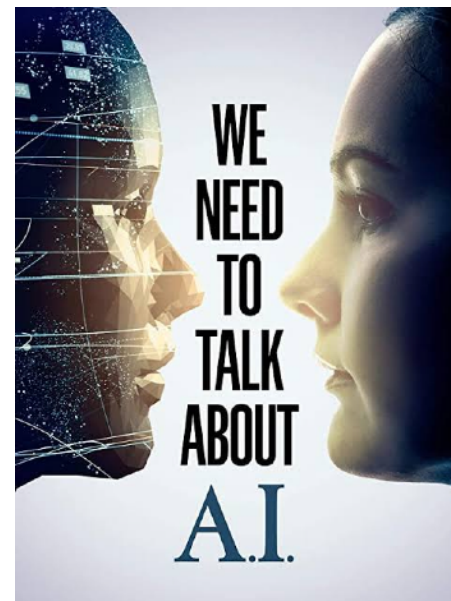


If a new AE is to be standardized, we should be more ambitious:  
Make it AE5, committing, and with best-possible, one-pass resistance to nonce reuse

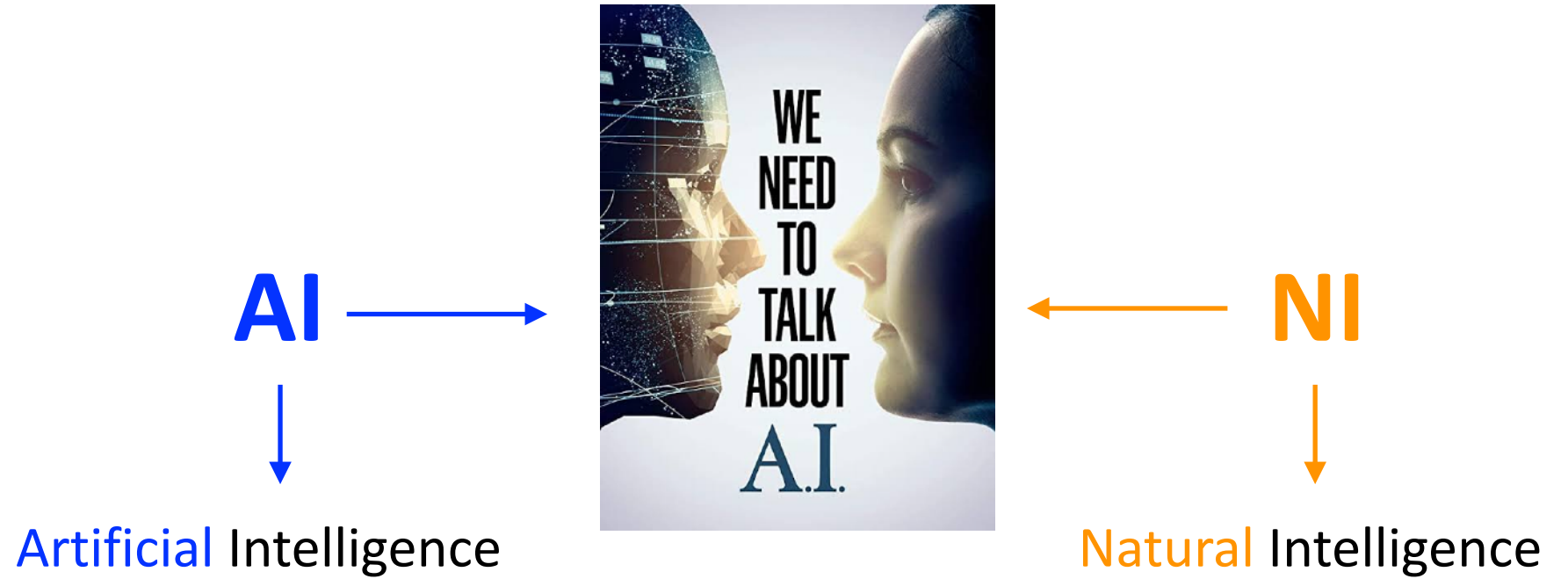




I failed ...



## Some notation



We have seen that AI can solve non-trivial, open research problems.

Ones that NI cannot (or did not) solve.

# Ten Advances in Mathematics and Theoretical Computer Science

OpenAI

We present a collection of results obtained by an internal OpenAI model, spanning mathematics and theoretical computer science:<sup>1</sup>

1. **High-dimensional sphere packing.** The asymptotic strength of the Cohn-Elkies linear program is determined exactly. This gives an improved general packing bound in high dimensions and settles the corresponding Fourier sign-uncertainty problem asymptotically.
2. **Binary and spherical codes.** Classical upper bounds for fixed-distance binary and spherical codes are improved by exponential factors for all parameters. The spherical construction also recovers the sphere-packing exponent of Chapter 1.
3. **Nonsofic groups exist.** An explicit nonsofic group is constructed, answering the longstanding question of whether every countable group is sofic. The proof combines work of Kun and Kun-Thom with a combinatorial expander-matching argument, realized using the binary Leavitt algebra and Thompson's group  $V$ .
4. **Connes's rigidity conjecture.** Infinitely many pairwise nonisomorphic groups with property  $(T)$  are constructed with the same group von Neumann algebra, disproving Connes's conjecture and answering a related finite-to-one question of Popa.
5. **Arithmetic circuit complexity.** For the permanent, division-free circuits require  $\Omega(n^2 \log \log n)$  gates, while formulas require  $\Omega(n^4 / \log n)$  leaves.
6. **Quantum parallel repetition.** Exponential parallel repetition is proved for every finite two-player entangled game, extending the classical repetition principle beyond previously treated special classes of quantum games.
7. **Closest vector problem.** A direct reduction from 3SAT gives  $n^{1/400}$ -factor hardness for the Euclidean closest vector problem, with related consequences for binary decoding and other lattice norms.
8. **Ehrhart's volume conjecture.** The sharp volume upper bound  $(n+1)^n/n!$  is proved in every dimension for convex bodies whose barycenter is their only interior lattice point.
9. **Multicolor Ramsey numbers.** A new superexponential lower bound shows that  $R_k(3)$  grows as  $k^{\Theta(k)}$ .
10. **Compactness and degeneracy.** Separate bipartite graph constructions disprove two conjectures in extremal graph theory: the compactness conjecture of Erdős and Simonovits and a degeneracy conjecture of Erdős.

We have seen that AI can solve non-trivial,  
open research problems.

Ones that NI cannot (or did not) solve.

In cryptography, AI has found new proofs, results and attacks.  
As witnessed by recent ePrint papers.

AI capabilities will grow.

We consider some questions, or changes, for the (cryptographic) research community, in this new world.

## Disclaimers and caveats:

I am not an expert.

What I say is not likely to be new.

You know these things, have pondered and discussed them too.

The list here is certainly not exhaustive; there are many other things to consider.

But it seems silly to NOT discuss what is in front of us.

And perhaps this helps structure the conversation.

## Important questions that I will NOT discuss:

What do we do about the exploding number of conference submissions?

What do we do about peer review?

In fact I will have no answers, just questions.

## Democratization of research?

We will see (good) research being produced by a much larger set of people. Special qualifications (like a PhD) may not be needed.

The current notion of a research community may no longer make sense.

We will see (good) research being produced by a much larger set of people. Special qualifications (like a PhD) may not be needed.

The current notion of a research community may no longer make sense.



Identity crisis?

Ich bin ein Cryptographer.

Topic bias?

Research will focus more on topics  
where AI is good and can help

And diminish on other topics.

## Topic bias?

Currently

Research will focus more on topics  
where AI is good and can help

And diminish on other topics.

Clearly formulated mathematical  
problems, attacks and assumption  
breaking, proof checking, ...

New schemes, new definitions, ...

But this can change as AI evolves

AI produces writes but who or what consumes reads ?

Why do we do research and publish papers?

AI produces writes but who or what consumes reads ?

Why do we do research and publish papers?

To make ``scientific advances.”  
To solve real-world problems.  
To enhance our egos.

AI produces writes but who or what consumes reads ?

Why do we do research and publish papers?

To make ``scientific advances.”  
To solve real-world problems.  
To enhance our egos.



AI may further these goals ...

AI produces writes but who or what consumes reads ?

Why do we do research and publish papers?

But also

Research and publication  
is a conversation  
amongst **PEOPLE**  
that gives us a sense of connection.

My bias:

I may read a paper because it is by an author  
in whose views I am interested.  
When I see that the results in a paper are  
largely by AI, I may lose interest in reading it.

AI produces writes but who or what consumes reads ?

Why do we do research and publish papers?

But also

Research and publication  
is a conversation  
amongst **PEOPLE**  
that gives us a sense of connection.



Does this remain when AI does the work?

AI produces writes but who or what consumes reads ?

Why do we do research and publish papers?

But also

Research is fun!

We have a sense of accomplishment  
and satisfaction.

AI produces writes but who or what consumes reads ?

Why do we do research and publish papers?

But also

Research is fun!

We have a sense of accomplishment  
and satisfaction.



Does this remain when AI does the work?

## Human expertise in the age of AI?

Pre-AI, researchers became experts in technical domains, like mathematics. They developed different intellectual skills.

To what extent will this be needed, or sought, post-AI?

Maybe the old skills are less necessary.

Maybe SMART PROMPTING will be the new skill.

What does this mean for education and the academic infrastructure?

AI produces  
writes but who or what verifies ?

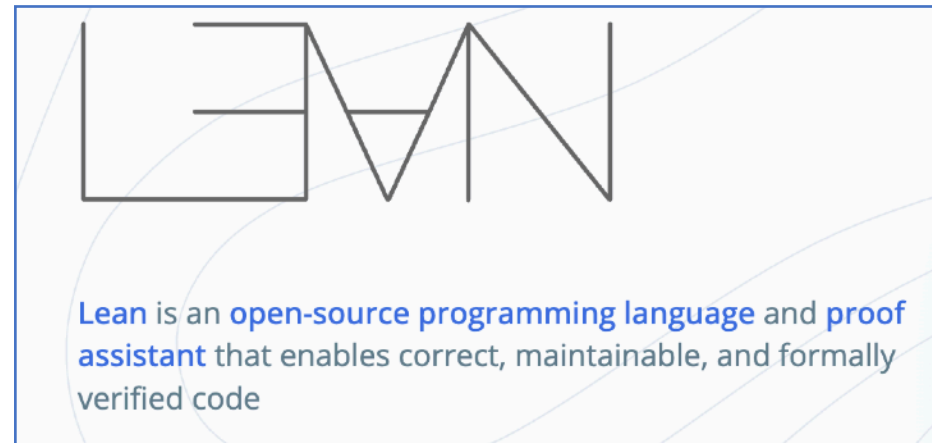
AI-produced results seem right now to mostly be getting conscientious human verification.

How long will this, or can this, persist?

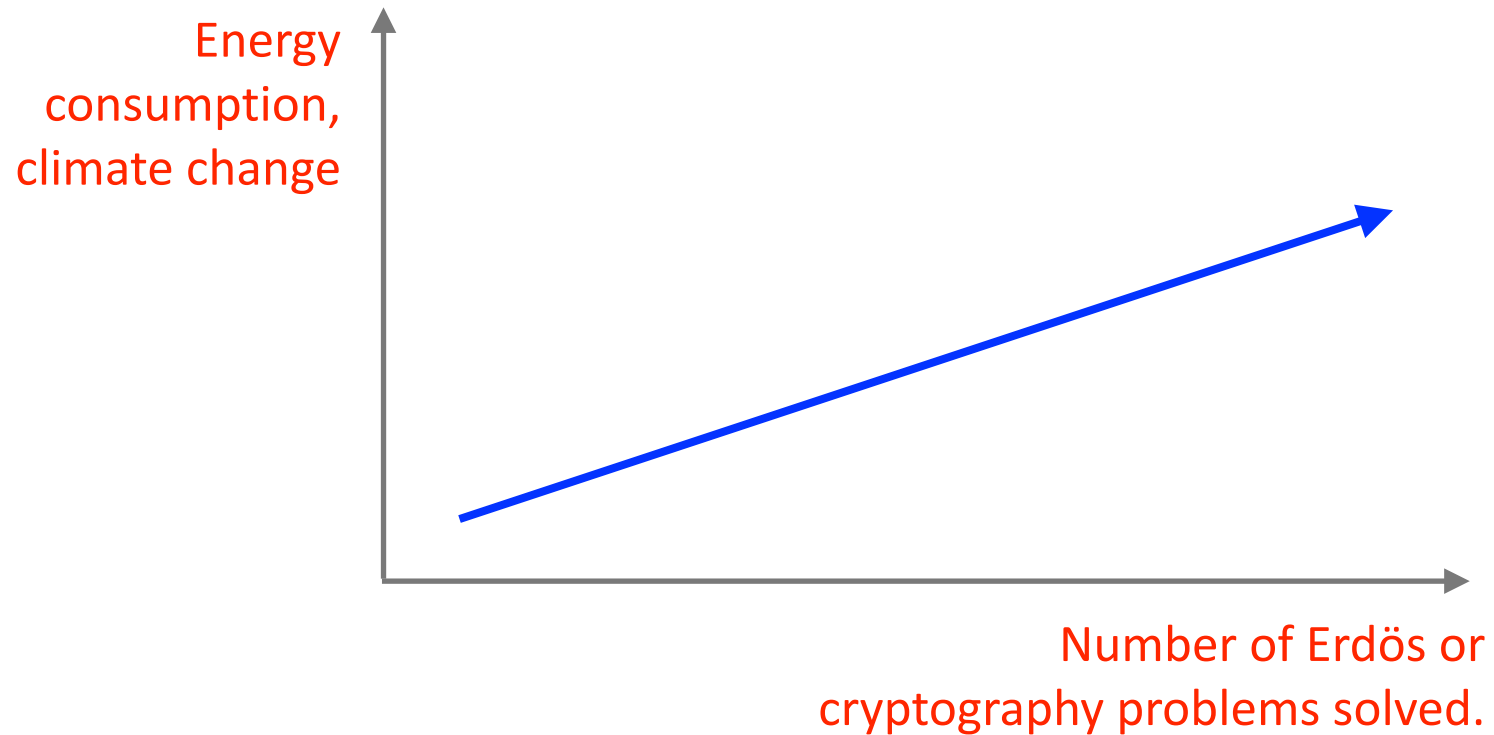
If human technical skill diminishes, will NI have the ability to verify?

If AI results are usually correct, will there remain incentive for NI to verify?

Already the trend is to ask AI to produce **Lean** proofs that are automatically verified.

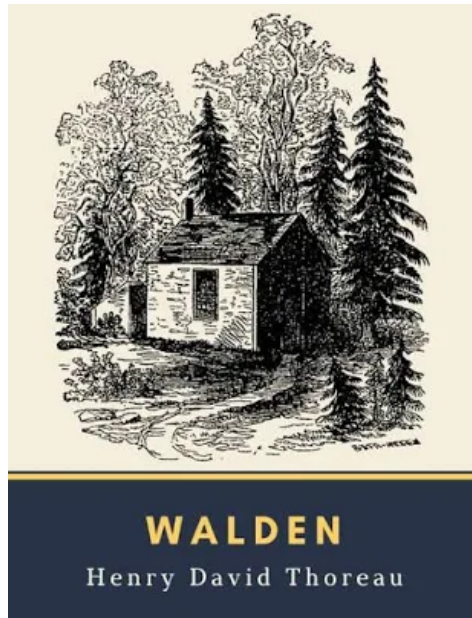


Is the environmental impact worth the scientific advances?



A data center, somewhere





**Our inventions are ... but an improved means  
to an unimproved end.**

I am not an AI hater or AI denier.  
I fully see and acknowledge the scientific advances it brings.  
I use it.  
AI has had, and will have, a lot of benefits.

However:

Scientific and technical advances are good, but they are secondary.  
What is primary is human well being.  
My questions aim to bring this back into focus.

## Summary of questions about AI in cryptography research

Democratization of research

Topic Bias

If AI produces and writes, who consumes and reads?

Will human expertise change? Diminish?

Who verifies?

Is the impact on climate change worth the new results?

Can we improve the ends, not just the means?

- .
- .
- .